



Siempresoft EIRL

METODOLOGÍA DE EVALUACIÓN Y TRATAMIENTO DE RIESGOS

Versión:	0.10
Fecha de la versión:	21/11/2025
Creado por:	Ana Karim Salazar
Aprobado por:	Milton Guevara
Nivel de confidencialidad:	Restringida

Historial de modificaciones

Fecha	Versión	Creado por	Descripción de la modificación
21-08-2018	0.1	Junior Cachay	Versión inicial del documento
24-10-2019	0.2	Ana Karim Salazar	El perfil de puesto de "Jefe de Seguridad de la información" pasa a "Asistente de Seguridad de la Información". En el punto 3.6. Informes, el tiempo cambia de ".... mensualmente cada último viernes hábil del mes." a " ... trimestralmente la última semana del mes." En 4. Gestión de registros guardados en base a este documento, Nombre del archivo: "Informe sobre evaluación y tratamiento de riesgos (formulario electrónico, en formato PDF)", "Declaración de aplicabilidad (formulario electrónico, en formato PDF", "Plan de tratamiento de riesgos (formulario electrónico, documento de Word)" y "Plan de tratamiento de riesgos (formulario electrónico, documento de Word)" también estarán ubicados en el ordenador del Gerente General. Cambia rol de "Jefe de Seguridad de la Información" a "Solamente el Gerente General puede permitir a otros colaboradores el acceso a los documentos mencionados precedentemente".
30-11-2019	0.3	Ana Karim Salazar	- Cambia término "empleados" por "colaboradores" - En el 4. Gestión de registros guardados en base a este documento, cambia la Ubicación de archivo a todos registros de "Ordenador del Asistente de Seguridad de la Información" por "Repositorio de documentos online de Siempresoft / 04 - Área de Seguridad de la Información / Gestión de Riesgos / Vigentes" - En el 5. Validez y gestión de documentos, queda eliminado el 3er párrafo: "Al evaluar la efectividad y adecuación de este documento, es necesario tener en cuenta los siguientes criterios..."
18-11-2020	0.4	Ana Karim Salazar	Se agrega "se realiza al menos una vez por año" en: 3.5. Declaración de aplicabilidad y Plan de tratamiento del riesgo 3.6. Informes, se agrega al final del primer párrafo: al menos una vez al año.

21-07-2021	0.5	Ana Karim Salazar	Cambio de rol, de: "Asistente de seguridad de la información" por "Oficial de seguridad de la información" Cambio en el formato del Plan de tratamiento de riesgos
20/12/2021	0.6	Ana Karim Salazar	En 3.3. Tratamiento del riesgo , cambio en el término: De: En el caso de la opción 1 ..., para evaluar la " efectividad " de los controles planificados. por: "eficacia" se agrega nuevo ítem: 3.4. Medir la eficacia del control
01/03/2022	0.7	Ana Karim Salazar	Los cambios están detallados en el Repositorio de documentos online de Siempresoft /02 -Área de Seguridad de la Información / Anexos /Anexo N°7.pdf
03/07/2023	0.8	Ana Karim Salazar	Los cambios están detallados en el Repositorio de documentos online de Siempresoft /02 -Área de Seguridad de la Información / Anexos /Anexo N°15.pdf
22/11/2024	0.9	Ana Karim Salazar	Cambio en la fecha de vigencia
21/11/2025	0.10	Ana Karim Salazar	Incorporación en los puntos: 2. Documentos de referencia • Ley N° 29733, Ley de Protección de Datos Personales • Decreto Supremo N.° 16-2024-JUS, Decreto Supremo que aprueba el Reglamento de la Ley N° 29733, Ley de Protección de Datos Personales 3.3. Evaluación de riesgos - Gestión de datos personales 7. Gestión de registros guardados en base a este documento: Evaluación de riesgos de DP Modificación en el 1° registro del cuadro en el punto 7. Gestión de registros guardados en base a este documento de: Proceso de gestión de riesgos (Excel que contiene cuadros): - Activos de información, Identificación de riesgos, Evaluación de riesgos, Tratamiento de riesgos, Plan de tratamiento de riesgos a: Proceso de gestión de riesgos (Excel que contiene cuadros): - Activos primarios, Activos de soporte, Identificación de riesgos, Riesgos de proyectos, Activos tecnológicos, Plan de tratamiento de riesgos

Tabla de contenido

TABLA DE CONTENIDO	4
1. OBJETIVO, ALCANCE Y USUARIOS	5
2. DOCUMENTOS DE REFERENCIA	5
3. PROCESO DE GESTIÓN DE RIESGOS	5
3.1. COMUNICACIÓN Y CONSULTA	6
3.2. ESTABLECIMIENTO DEL CONTEXTO	6
3.2.1. Contexto interno y externo	6
3.2.2. Liderazgo y compromiso	7
3.2.3. Criterios básicos	7
3.3. EVALUACIÓN DE RIESGOS	7
a. Identificación del riesgo	7
b. Análisis del riesgo	8
c. Valoración del riesgo	8
3.4. TRATAMIENTO DEL RIESGO	10
3.5. SEGUIMIENTO Y REVISIÓN	11
4. MEDIR LA EFICACIA DEL CONTROL	11
5. DECLARACIÓN DE APLICABILIDAD Y PLAN DE TRATAMIENTO DEL RIESGO	11
6. INFORMES	12
7. GESTIÓN DE REGISTROS GUARDADOS EN BASE A ESTE DOCUMENTO	12
8. VALIDEZ Y GESTIÓN DE DOCUMENTOS	13

1. Objetivo, alcance y usuarios

El objetivo del presente documento es definir la metodología para evaluar y tratar los riesgos de seguridad de la información, ciberseguridad y privacidad; y definir el nivel aceptable de riesgo según la norma ISO/IEC 27001.

La evaluación y tratamiento de riesgos se aplican a todo el alcance del Sistema de gestión de seguridad de la información (SGSI); es decir, a todos los procesos y activos dentro del alcance o que pueden tener un impacto sobre la seguridad de la información en el ámbito del SGSI.

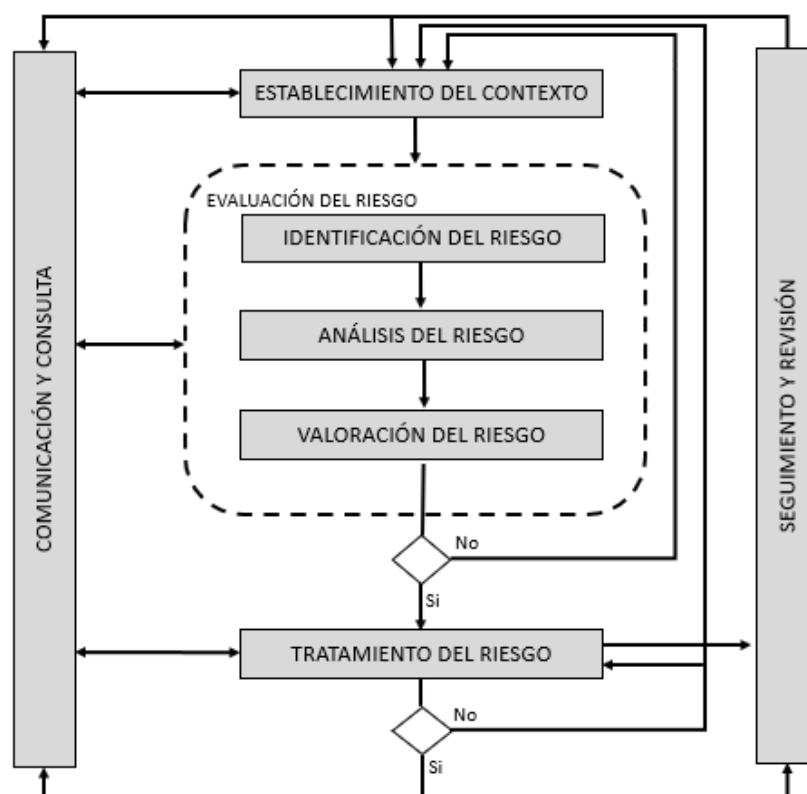
Los usuarios de este documento son todos los colaboradores de Siempresoft que participan en la evaluación y tratamiento de riesgos.

2. Documentos de referencia

- Norma ISO/IEC 27001
- Norma ISO/IEC 27005:2022
- NTP-IEC/ISO 31010:2017
- Política de seguridad de la información
- Lista de requisitos legales, normativos y contractuales y demás requisitos
- Ley N° 29733, Ley de Protección de Datos Personales
- Decreto Supremo N.° 16-2024-JUS, Decreto Supremo que aprueba el Reglamento de la Ley N° 29733, Ley de Protección de Datos Personales

3. Proceso de gestión de riesgos

Para la apreciación del riesgo y el proceso de gestión del riesgo se adopta al marco de referencia de las ISO 31000 y ISO 27005.



El proceso de gestión de riesgos lleva un enfoque iterativo que proporciona un buen equilibrio entre minimizar el tiempo y esfuerzo dedicados a identificar los controles y garantizar que los riesgos se evalúen adecuadamente. Siempresoft garantiza que las evaluaciones de riesgos produzcan resultados coherentes, válidos y comparables.

3.1. Comunicación y consulta

La comunicación acerca de los riesgos es intercambiada y compartida con los propietarios de los riesgos y la Alta Dirección ya que este proceso puede traer impactos significativos sobre las decisiones a tomar; además de emitir juicio sobre la identificación, tratamiento y aceptación de los riesgos.

Es una actividad importante, requiere que los propietarios de los riesgos aprueben los planes de tratamiento del riesgo y decidan sobre la aceptación de los riesgos residuales. Dependiendo de la naturaleza y sensibilidad de los riesgos, es permitido limitar cierta información según sea necesario teniendo en cuenta el nivel de detalle requerido por las diferentes partes interesadas, con el fin de evitar la publicidad de los riesgos más sensibles y debilidades conocidas.

Las comunicaciones de riesgo se pueden reenviar voluntariamente a terceros para permitir una mejor gestión o coordinación de respuesta; también pueden ser requeridas por reguladores o socios comerciales bajo ciertas circunstancias.

3.2. Establecimiento del contexto

3.2.1. Contexto interno y externo

Tener una comprensión de alto nivel sobre los problemas que afectan al SGSI, conocer el contexto interno/externo que es relevante y que influyen en la gestión de riesgos seguridad de la información y los requisitos de las partes interesadas.

3.2.2. Liderazgo y compromiso

La Alta Dirección lidera e impulsa las evaluaciones de riesgo:

- Vela que se asignen los recursos necesarios a la gestión del riesgo
- Asigna autoridad y responsabilidad dentro de la empresa

El Oficial de Seguridad de la información es responsable de gestionar los riesgos.

3.2.3. Criterios básicos

La valoración del riesgo se determina de acuerdo con los siguientes criterios:

- Valoración de riesgo: Según el valor de los procesos de negocio, criticidad de los activos implicados y su afectación al CID, importancia operacional, obligaciones legales y prestigio de la empresa.
- Evaluación del impacto: mediante el grado de daño del activo u operaciones temporal o permanente, pérdidas financieras, alteración en los planes y daño en la reputación de la empresa.
- Aceptación del riesgo: Puede variar según cuanto tiempo se espera que exista el riesgo, los objetivos de la empresa, restricciones tecnológicas, recurso financiero disponible, factores humanos e intereses de las partes interesadas.

3.3. Evaluación de riesgos

La evaluación del riesgo determina el valor de los activos de información, identifica las amenazas y vulnerabilidades posibles o existentes. Cuantifica o describe cualitativamente el riesgo y permite priorizar un riesgo de acuerdo con su percepción de la gravedad, en sus consecuencias y probabilidad u otros criterios establecidos. Dentro de la evaluación de riesgo también se consideran a otros procesos como:

- Gestión de proyectos
- Gestión de vulnerabilidades
- Gestión de incidentes
- Gestión de cambio
- Gestión de datos personales

El flujo consta de las siguientes actividades:

a. Identificación del riesgo

Tener identificados todos los activos que están dentro del alcance del SGSI; es decir, todos los activos que pueden afectar la confidencialidad, integridad y disponibilidad de la información. Al identificar los activos también es necesario identificar a sus propietarios (la persona o unidad organizativa).

Los activos se pueden dividir en dos categorías:

- activos primarios/de negocio: información o procesos de valor para la empresa;
- activos de apoyo: componentes del sistema de información en los que se basan uno o varios activos comerciales (físico o digital).

Siempresoft adopta un enfoque basado en eventos que consta en identificar escenarios estratégicos a través de diversas fuentes de riesgo y su impacto hacia las partes interesadas. Los propietarios del riesgo buscan eventos, situaciones nuevas o modificadas que pueden afectar el logro de los objetivos de seguridad de la información. En este enfoque los riesgos son identificados y evaluados mediante una valoración de eventos y consecuencias haciendo uso de datos históricos o basado en el juicio de expertos. Esto permite centrar los esfuerzos de tratamiento en los riesgos críticos.

b. Análisis del riesgo

El análisis se puede realizar a partir de las consecuencias para la seguridad de la información, las causas y fuentes de riesgo, la probabilidad de ocurrencia y gravedad, considerar la presencia (o no) y la eficacia de los controles existentes. Para cada riesgo es necesario identificar un propietario, se considera como propietario del riesgo el mismo propietario del activo quien es responsable y tiene autoridad para gestionar el riesgo.

Los activos primarios/de negocio se utilizan a menudo en el enfoque basado en eventos (identificación de eventos y sus consecuencias en los activos comerciales). Los activos de apoyo a menudo se utilizan en el enfoque basado en activos (identificación y análisis de vulnerabilidades y amenazas sobre estos activos) y en el proceso de tratamiento de riesgos (especificación de los activos a los que se debería aplicar cada control).

Los escenarios de riesgo se pueden construir utilizando un enfoque basado en eventos o un enfoque basado en activos o ambos.

c. Valoración del riesgo

Es el proceso para comparar los resultados del análisis de riesgo con los criterios de riesgo, determinar si el riesgo es aceptable y priorizar los riesgos a tratar.

La valoración de riesgo se basa en la comparación del riesgo evaluado con los criterios de aceptación definidos, idealmente teniendo en cuenta el grado de confianza en la evaluación. Los niveles de riesgo se pueden validar en consenso entre los propietarios de riesgos y la Alta Dirección. Es importante que los propietarios de riesgos tengan una buena comprensión de los riesgos de los que son responsables que concuerde con los resultados de la evaluación objetiva.

Los criterios de riesgo utilizados para priorizar los riesgos deben considerar los objetivos del negocio, los requisitos contractuales, legales y reglamentarios y las opiniones de las partes interesadas relevantes.

Escala	Consecuencia	Descripción
5 - Catastrófico	Consecuencias sectoriales o regulatorias más allá de la organización	Ecosistemas del sector afectados con consecuencias que pueden ser duraderas. La pérdida de CID tiene consecuencias críticas e irreparables sobre la seguridad de las personas, las

		finanzas, las operaciones, las obligaciones legales o el prestigio de la organización.
4 - Crítico	Consecuencias desastrosas para la organización	Incapacidad para asegurar la totalidad o parte de las actividades, La pérdida de CID tiene posibles consecuencias graves para la seguridad de las personas, las finanzas, las operaciones, obligaciones legales o el prestigio de la organización. Probabilidad de no superar la situación. Los sectores de actividad o sectores estatales en los que opera probablemente se verán afectados levemente, sin consecuencias duraderas.
3 - Serio	Consecuencias sustanciales para la organización	Alta degradación en el desempeño de la actividad. La pérdida de CID tiene posibles consecuencias sustanciales sobre la seguridad de las personas, las finanzas, las operaciones, obligaciones legales o el prestigio de la organización. La organización superará la situación con serias dificultades. Sin impacto sectorial ni estatal.
2 - Significativo	Consecuencias significativas pero limitadas para la organización	Degradación en el desempeño de la actividad. La pérdida de CID tiene consecuencias significativas para la seguridad de las personas, las finanzas, las operaciones, obligaciones legales o el prestigio de la organización. La organización superará la situación a pesar de algunas dificultades
1 - Menor	Consecuencias insignificantes para la organización	La pérdida de CID no tiene consecuencias sobre las operaciones, el desempeño de la actividad o sobre la seguridad de las personas, las finanzas, las operaciones, obligaciones legales o el prestigio de la organización. La organización superará la situación sin demasiada dificultad

Luego de la evaluación de consecuencias es necesario evaluar la probabilidad de que se materialice ese riesgo; es decir, la probabilidad de que una amenaza se aproveche de la vulnerabilidad del activo en cuestión.

1 - Improbable	La fuente de riesgo tiene muy pocas posibilidades de alcanzar su objetivo, la probabilidad del escenario de riesgo es muy baja Los controles de seguridad existentes son seguros y hasta el momento han suministrado un adecuado nivel de protección. En el futuro no se esperan incidentes nuevos.
2 – Bastante improbable	La fuente de riesgo tiene pocas posibilidades de alcanzar su objetivo, la probabilidad del escenario de riesgo es baja. Los controles de seguridad existentes son seguros y hasta el momento han suministrado un adecuado nivel de protección. Pueden cambiar con el tiempo y en el futuro pueden surgir incidentes nuevos.
3 - Probable	La fuente de riesgo puede alcanzar su objetivo, la probabilidad del escenario de riesgo es significativa. Los controles de seguridad existentes son moderados y en general han suministrado un adecuado nivel de protección. Es posible la ocurrencia de nuevos incidentes.

4 – Muy probable	La fuente de riesgo probablemente alcanzará su objetivo, la probabilidad del escenario de riesgo es alta. Los controles de seguridad existentes son bajos. Existe una gran probabilidad de que haya incidentes así en el futuro.
5 – Casi seguro	La fuente de riesgo seguramente alcanzará su objetivo, la probabilidad del escenario de riesgo es muy alta. No existen controles de seguridad. Existe una gran probabilidad de que haya incidentes a corto plazo.

El nivel de riesgo se obtiene de manera cualitativa entre consecuencia y probabilidad, los controles de seguridad existentes son ingresados en la última columna del Cuadro de evaluación de riesgos.

Probabilidad	Consecuencia				
	1 - Menor	2 - Significativo	3 - Serio	4 - Crítico	5 - Catastrófico
1 - Improbable	Muy bajo	Muy bajo	Bajo	Bajo	Bajo
2 – Bastante improbable	Muy bajo	Bajo	Bajo	Medio	Medio
3 – Probable	Bajo	Bajo	Medio	Alto	Alto
4 – Muy probable	Bajo	Medio	Alto	Alto	Muy alto
5 – Casi seguro	Medio	Alto	Alto	Muy alto	Muy alto

Nivel de riesgo

Riesgo bajo: Muy bajo, Bajo

Riesgo medio: Medio

Riesgo alto: Muy alto, Alto

Criterios para la aceptación de riesgos: Los niveles bajo y medio son riesgos aceptables, mientras que los niveles alto y muy alto son riesgos no aceptables. Los riesgos no aceptables deben ser tratados acorde a la importancia del proceso de negocio.

* La selección de las técnicas debe permitir comprender la naturaleza del riesgo, debe ser repetible, verificable y que permita hacer seguimiento.

3.4. Tratamiento del riesgo

El tratamiento de riesgos se implementa trasladando de la evaluación de riesgos todos los riesgos identificados como no aceptables. El tratamiento de riesgos es realizado por el Oficial de Seguridad de la Información.

Para los riesgos calificados como Alto y Muy alto se deben seleccionar una o más opciones de tratamiento.

1. Elección de control o controles de seguridad del Anexo A de la norma ISO/IEC 27001 u otros controles de seguridad.
2. Transferencia de los riesgos a terceros; por ejemplo, suscribiendo una póliza de seguros o un contrato con proveedores o socios.
3. Evitar los riesgos discontinuando una actividad comercial que ocasiona ese riesgo.
4. Aceptación del riesgo: esta opción está permitida solamente si la selección de otras opciones de tratamiento del riesgo costaría más que el potencial impacto en el caso de que se materializara dicho riesgo. La decisión debe ser registrada formalmente.

La elección de opciones se implementa a través del Cuadro de tratamiento de riesgos.

En el caso de la opción 1 (elección de controles de seguridad): Los controles deben proveer protección como: corrección, eliminación, prevención, minimización del impacto, disuasión, detección, recuperación, seguimiento y concientización. Durante la selección del control, es importante balancear el costo de adquisición, implementación, administración, operación, seguimiento y mantenimiento de los controles contra el valor de los activos que están siendo protegidos. Cuando se escogen varios controles de seguridad para un riesgo, se insertan filas adicionales en la tabla, inmediatamente debajo de la fila en que se especifica el riesgo.

Los controles están clasificados en preventivos, de detección y correctivos, para asegurar que la elaboración del plan de tratamiento de riesgos sea resiliente a las fallas de control.

El tratamiento de riesgos relacionados con procesos externalizados debe ser atendido por medio de contratos con los terceros responsables, como se especifica en la Política de seguridad para proveedores. Cabe señalar que puede ser posible compartir la responsabilidad de gestionar el riesgo, pero normalmente no es posible compartir la responsabilidad por un impacto. Los clientes suelen atribuir un impacto adverso como si fuera una falla de la organización.

* Considerar las restricciones que pueden afectar la selección de los controles ya que pueden obstaculizar el uso de otros controles o pueden inducir a errores humanos ocasionando un aumento al riesgo.

3.5. Seguimiento y revisión

Los propietarios de riesgos deben revisar los riesgos vigentes y deben actualizar con los nuevos riesgos identificados. La revisión se realiza al menos una vez por año, o con mayor frecuencia en caso de cambios organizacionales significativos, nuevos activos incluidos, cambios importantes en tecnología, en los objetivos de negocios, en el entorno empresarial, leyes etc.

El Oficial de Seguridad de la Información supervisará el progreso de la implementación del Plan de tratamiento de riesgos e informará los resultados al Gerente General trimestralmente la última semana del mes.

Cualquier mejora acordada al proceso de gestión de riesgos de seguridad de la información, debe ser notificado a los involucrados para tener la seguridad de que no se pasa por alto ningún riesgo o elemento de riesgo y se tomen las medidas necesarias para proporcionar una comprensión realista del riesgo y la capacidad de respuesta.

4. Medir la eficacia del control

Cada control implementado en el cuadro de tratamiento de riesgos será medido con la fórmula siguiente:

$$\text{Eficacia} = (\text{Resultado alcanzado} * 100) / \text{Resultado previsto}$$

La puntuación es del 1 al 5, siendo 1 muy ineficaz y 5 muy eficaz.

5. Declaración de aplicabilidad y Plan de tratamiento del riesgo

La Declaración de aplicabilidad se produce de la evaluación de riesgos para identificar los controles necesarios y del plan de tratamiento de riesgos para identificar aquellos que se planean implementar.

Solo los controles identificados en la evaluación de riesgos pueden incluirse en la Declaración de aplicabilidad, no se pueden agregar controles independientes de la evaluación de riesgos.

El Oficial de Seguridad de la Información debe documentar en la Declaración de aplicabilidad: qué controles de seguridad del Anexo A de la norma ISO/IEC 27001 son aplicables y cuáles no, la justificación de esa decisión y si están implementados o no. El estado de implementación de todos los controles puede declararse como “implementado”, “parcialmente implementado” o “no implementado”.

El Oficial de Seguridad de la Información preparará el Plan de tratamiento de riesgos con la implementación de los controles, las acciones del plan de tratamiento de riesgos deberían clasificarse por orden de prioridad en relación con el nivel de riesgo y la urgencia del tratamiento. En nombre de los propietarios de riesgos, la Gerencia General aceptará todos los riesgos residuales a través de la Declaración de aplicabilidad y aprobará el Plan de tratamiento de riesgos.

La revisión y actualización del Plan de tratamiento de riesgos se realiza al menos una vez por año.

6. Informes

El Oficial de Seguridad de la Información documenta los resultados de la evaluación y del tratamiento de riesgos, y de todas las revisiones subsiguientes, en el Informe de evaluación y tratamiento de riesgos, al menos una vez al año.

7. Gestión de registros guardados en base a este documento

Nombre del registro	Ubicación de archivo	Persona responsable del archivo	Controles para la protección del registro	Tiempo de retención
Proceso de gestión de riesgos (Excel que contiene cuadros): - Activos primarios, - Activos de soporte, - Identificación de riesgos - Riesgos de proyectos - Activos tecnológicos - Plan de tratamiento de riesgos	RDOS / 02 - Área de Seguridad de la Información / Gestión de Riesgos / Vigentes	Oficial de Seguridad de la Información	Solamente el Oficial de Seguridad de la Información tiene derecho a crear entradas y a realizar modificaciones en el archivo	Los datos son archivados de forma permanente
Evaluación de riesgos de DP	RDOS / 02 - Área de Seguridad de la Información / Gestión de Riesgos / Vigentes	Oficial de Seguridad de la Información	Solamente el Oficial de Seguridad de la Información tiene derecho a crear entradas y a realizar modificaciones en el archivo	Los datos son archivados de forma permanente
Informe sobre evaluación y tratamiento de riesgos (formulario)	RDOS / 02 - Área de Seguridad de la Información /	Oficial de Seguridad de la Información	El Informe se prepara en formato PDF de sólo lectura	El informe es almacenado

electrónico, en formato PDF)	Gestión de Riesgos / Vigentes			por el plazo de 3 años.
Declaración de aplicabilidad (formulario electrónico, en formato PDF)	RDOS / 02 - Área de Seguridad de la Información / Gestión de Riesgos / Vigentes	Oficial de Seguridad de la Información	El Informe se prepara en formato PDF de sólo lectura	Las versiones no vigentes de la DdA son almacenadas por un plazo de 3 años.

Solamente el Gerente General puede permitir a otros colaboradores el acceso a los documentos mencionados precedentemente.

8. Validez y gestión de documentos

Este documento es válido hasta el 21/11/2026.

El propietario de este documento es el Oficial de Seguridad de la Información, que debe verificar y, si es necesario, actualizar el documento por lo menos una vez al año, antes de la revisión periódica sobre la evaluación de riesgos vigente.